



You Have One New Appwntment - Hacking Proprietary iCalendar Properties

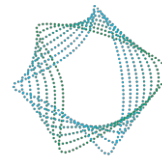
Eugene Lim, Government Technology Agency of Singapore

whoami

Eugene Lim

@spaceraccoonsec

Cyber Security Group,
Government
Technology Agency of
Singapore



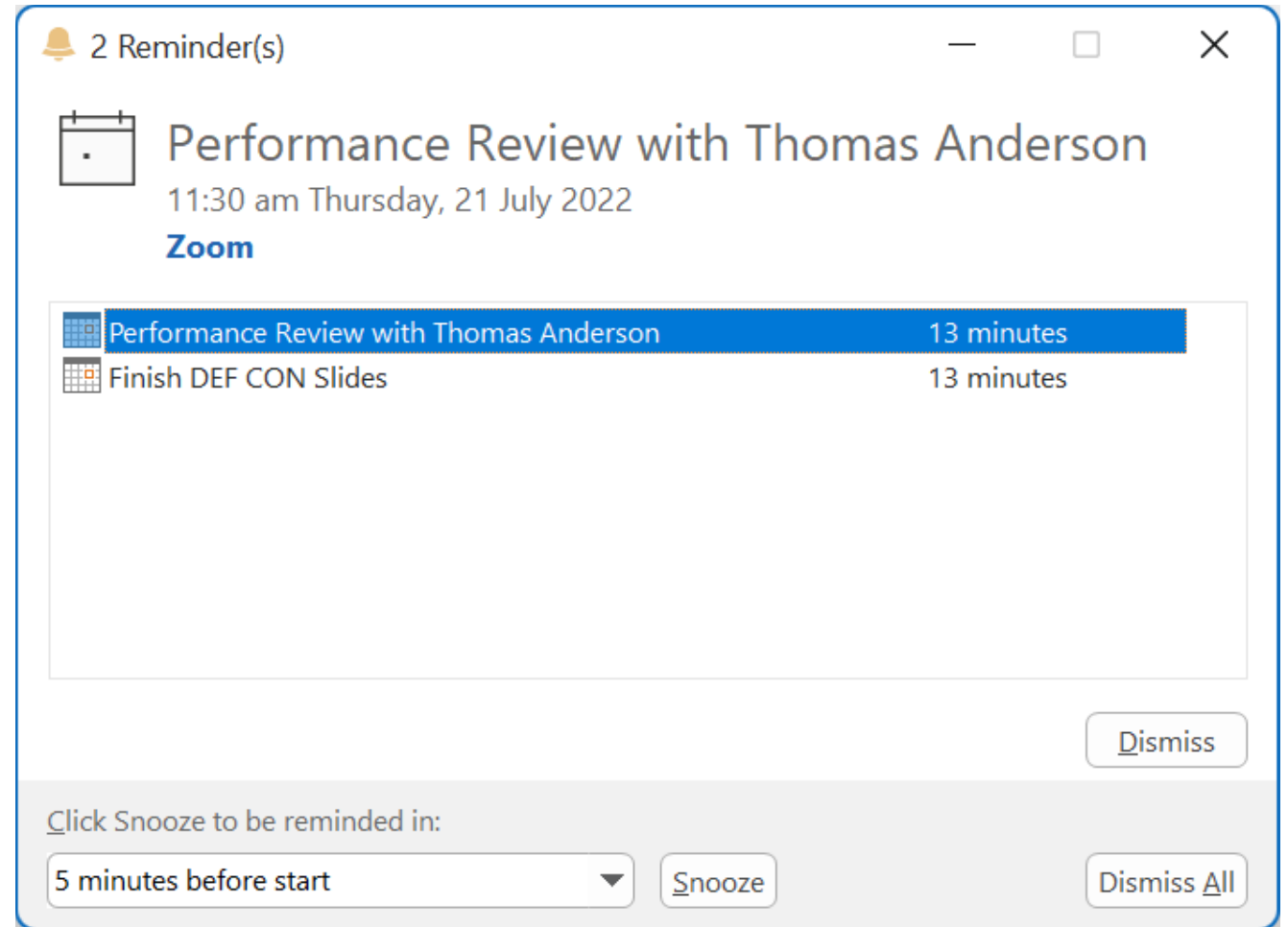
GOVTECH
SINGAPORE



CYBER SECURITY
GROUP

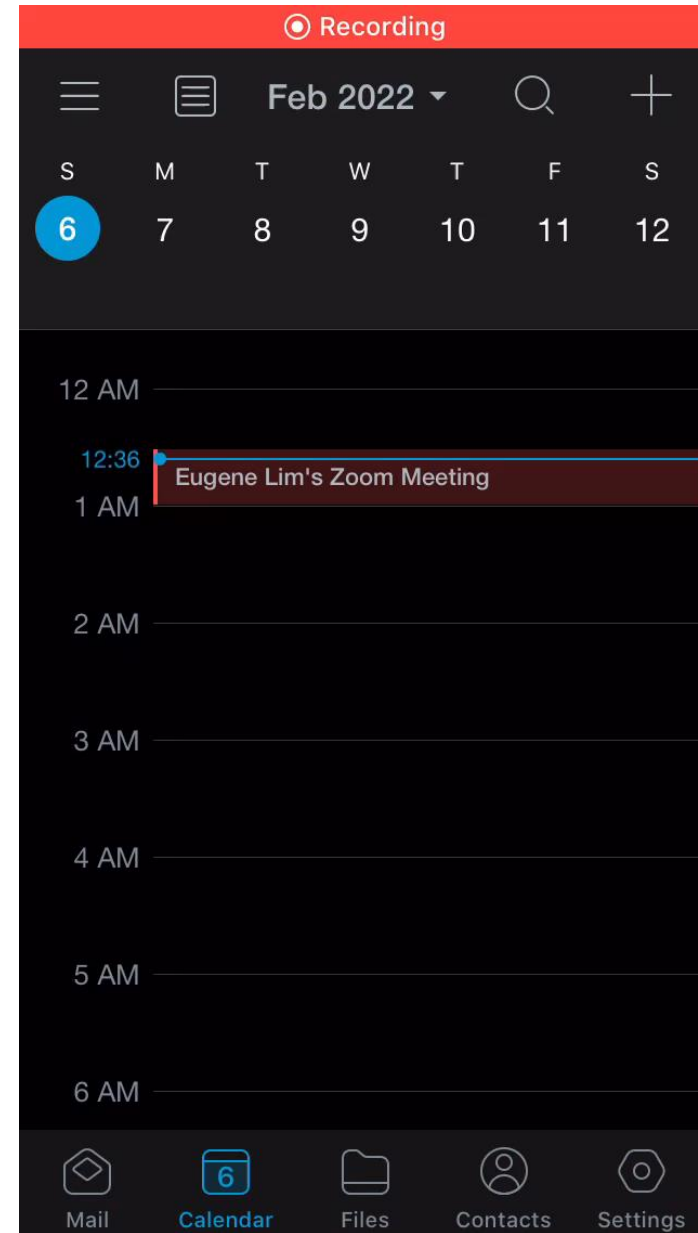


How often do you get this?



What if it did this?

You Have One New Appwntment



VMware Boxer
CVE-2022-22944

Synology
Calendar
CVE-2022-22682

Apple Calendar
PATCHED
(Monterey 12.4)

Microsoft
Outlook
RESOLVED

Google Calendar
BOUNTY

Nextcloud
Calendar
CVE-2022-24838
CVE-2022-31014

It all began in 1998...

Network Working Group
Request for Comments: 2445
Category: Standards Track

F. Dawson
Lotus
D. Stenerson
Microsoft
November 1998

Internet Calendaring and Scheduling Core Object Specification (iCalendar)

Status of this Memo

This document specifies an Internet standards track protocol for the Internet community, and requests discussion and suggestions for improvements. Please refer to the current edition of the "Internet Official Protocol Standards" (STD 1) for the standardization state and status of this protocol. Distribution of this memo is unlimited.

Copyright Notice

Copyright (C) The Internet Society (1998). All Rights Reserved.

Abstract

There is a clear need to provide and deploy interoperable calendaring and scheduling services for the Internet. Current group scheduling and Personal Information Management (PIM) products are being extended for use across the Internet, today, in proprietary ways. This memo has been defined to provide the definition of a common format for openly exchanging calendaring and scheduling information across the Internet.

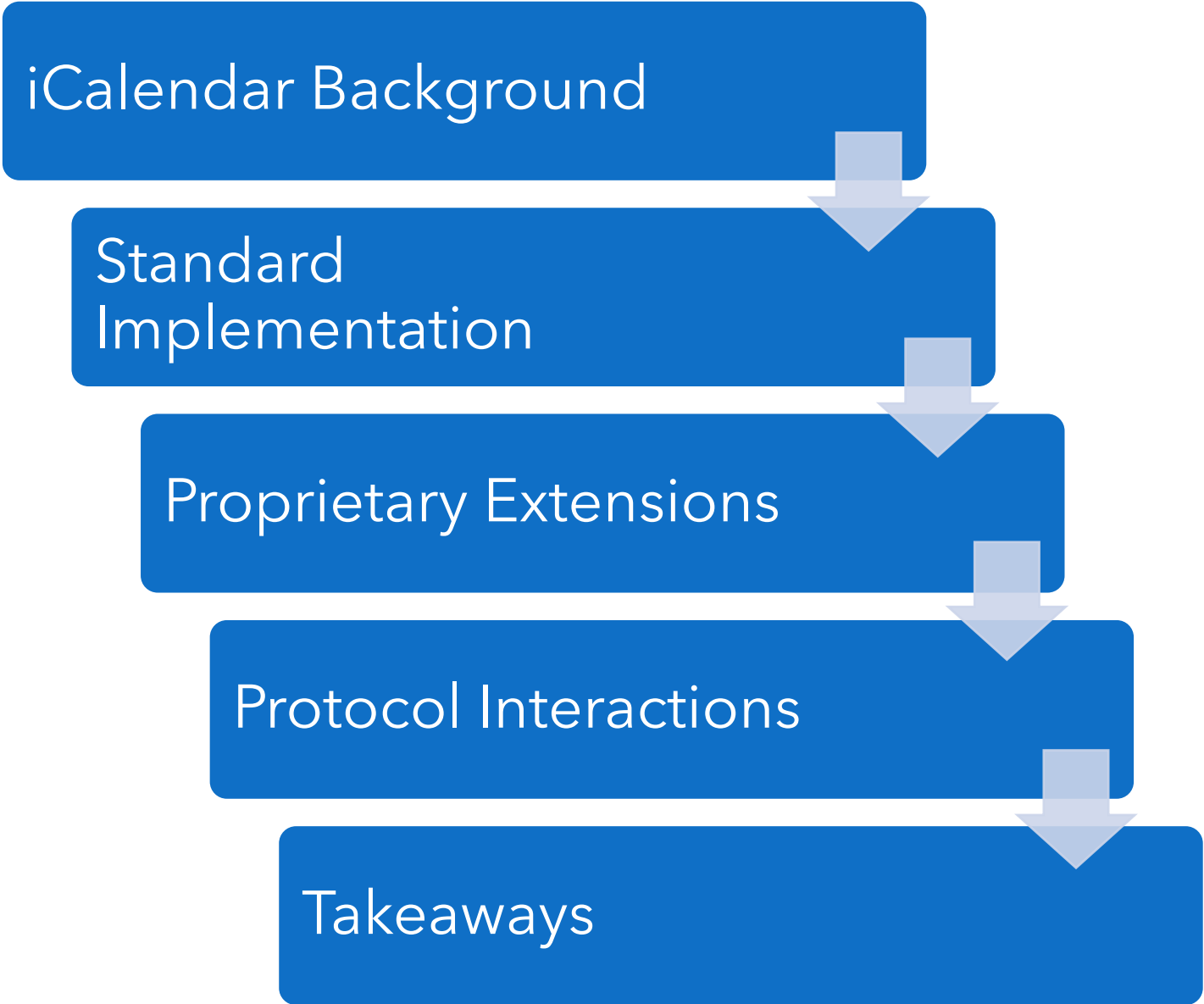
This memo is formatted as a registration for a MIME media type per [RFC 2048]. However, the format in this memo is equally applicable for use outside of a MIME message content type.

The proposed media type value is 'text/calendar'. This string would label a media type containing calendaring and scheduling information encoded as text characters formatted in a manner outlined below.

This MIME media type provides a standard content type for capturing calendar event, to-do and journal entry information. It also can be used to convey free/busy time information. The content type is suitable as a MIME message entity that can be transferred over MIME based email systems, using HTTP or some other Internet transport. In

Today's plan

iCalendar Background



Standard
Implementation

Proprietary Extensions

Protocol Interactions

Takeaways

Background on iCalendar Standard



Relevant RFCs

RFC 5545 (2009) - Desruisseaux (Oracle)

Internet Calendaring and Scheduling Core Object Specification (iCalendar)

RFC 5546 (2009) - Daboo (Apple)

iCalendar Transport-Independent Interoperability Protocol (iTIP)

RFC 7986 (2016) - Daboo (Apple)

New Properties for iCalendar

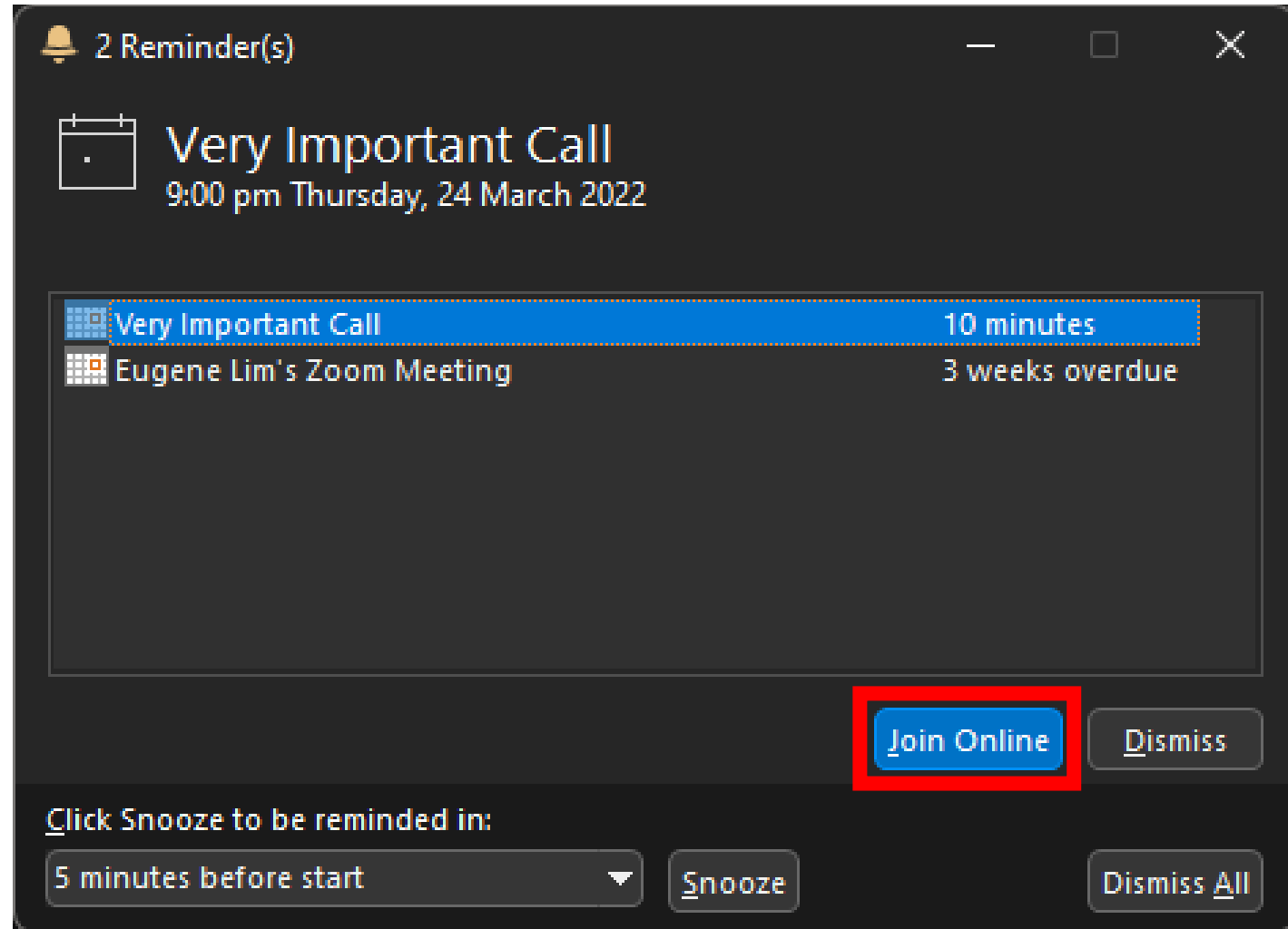
Also RFC6868, RFC7529, RFC7953, RFC9073, RFC9074...

Sample iCalendar

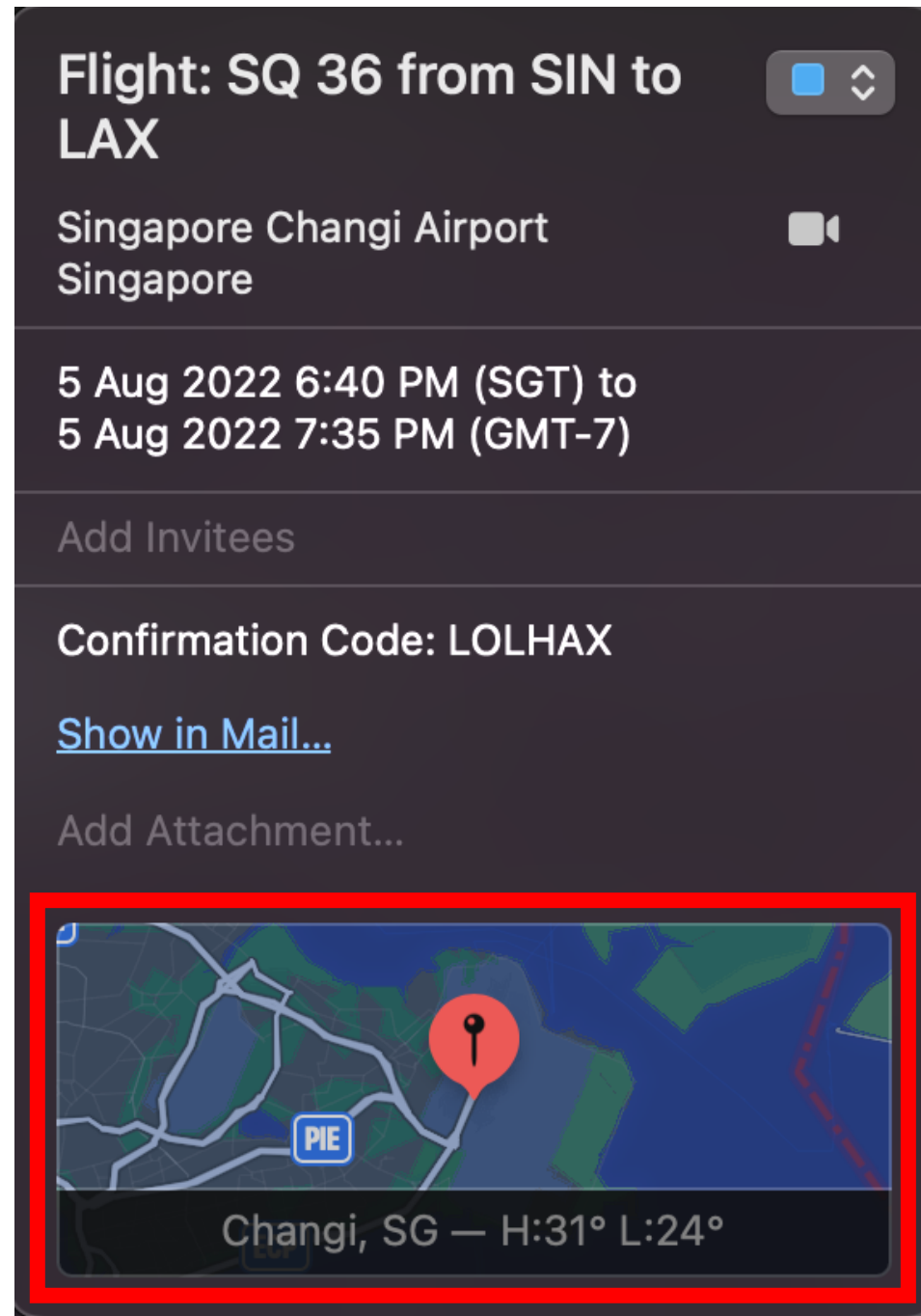
You Have One New Appwntment

```
BEGIN:VCALENDAR
VERSION:2.0
PRODID:-//ZContent.net//Zap Calendar 1.0//EN
CALSCALE:GREGORIAN
METHOD:PUBLISH
BEGIN:VEVENT
SUMMARY:Abraham Lincoln
UID:c7614cff-3549-4a00-9152-d25cc1fe077d
SEQUENCE:0
STATUS:CONFIRMED
TRANSP:TRANSPARENT
RRULE:FREQ=YEARLY;INTERVAL=1;BYMONTH=2;BYMONTHDAY=12
DTSTART:20080212
DTEND:20080213
DTSTAMP:20150421T141403
CATEGORIES:U.S. Presidents
LOCATION:Hodgenville\, Kentucky
GEO:37.5739497;-85.7399606
DESCRIPTION:Born February 12\, 1809\nSixteenth
URL:http://americanhistorycalendar.com/abraham-lincoln
END:VEVENT
END:VCALENDAR
```

**Proprietary
extensions
= more
features!**



Proprietary extensions = more features!



Dangerous by default?

```
BEGIN:VALARM
TRIGGER;RELATED=END:-P2D
ACTION:EMAIL
ATTENDEE:mailto:john_doe@example.com
SUMMARY:REMINDER: SEND AGENDA FOR WEEKLY STAFF MEETING
DESCRIPTION:Automatic draft agenda email.
ATTACH;FMTTYPE=application/msword:http://example.com/
  templates/agenda.doc
END:VALARM
```

```
BEGIN:VALARM
TRIGGER;VALUE=DATE-TIME:19970317T133000Z
REPEAT:4
DURATION:PT15M
ACTION:AUDIO
ATTACH;FMTTYPE=audio/basic:ftp://example.com/pub/
  sounds/bell-01.aud
END:VALARM
```

Insecure Implementations of Standard RFC Properties



DESCRIPTION property

Property Name: DESCRIPTION

Purpose: This property provides a more complete description of the calendar component than that provided by the "SUMMARY" property.

Value Type: TEXT

Example:

DESCRIPTION: Meeting to provide technical review for "Phoenix" design.\nHappy Face Conference Room. Phoenix design team MUST attend this meeting.\nRSVP to team leader.

**Vendors
implement
this very
differently..**

Plain Text

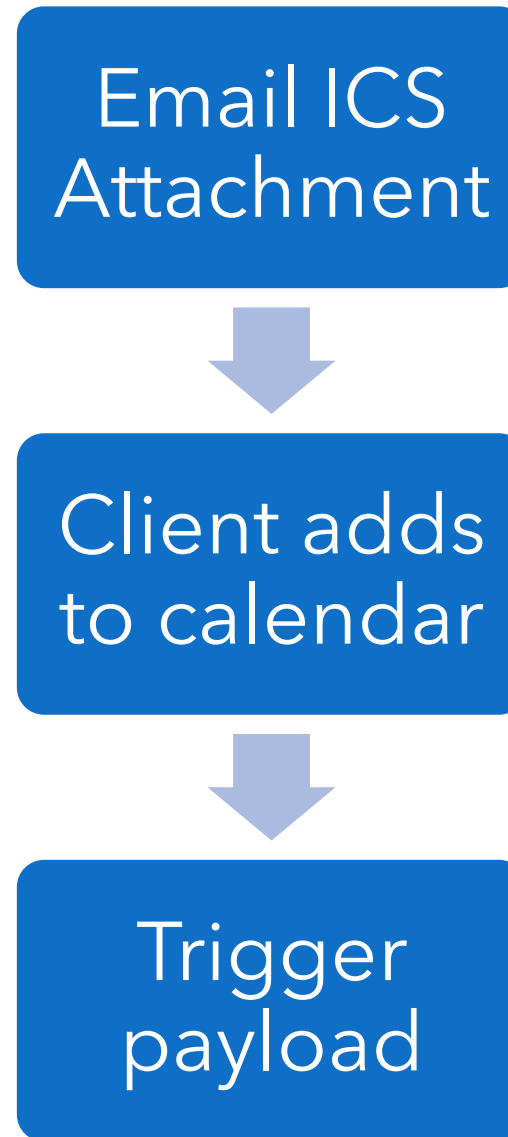
Apple
Microsoft

HTML

Google
VMware

Automatic payload delivery!

You Have One New Appwntment



Multiple client versions add to the mess.

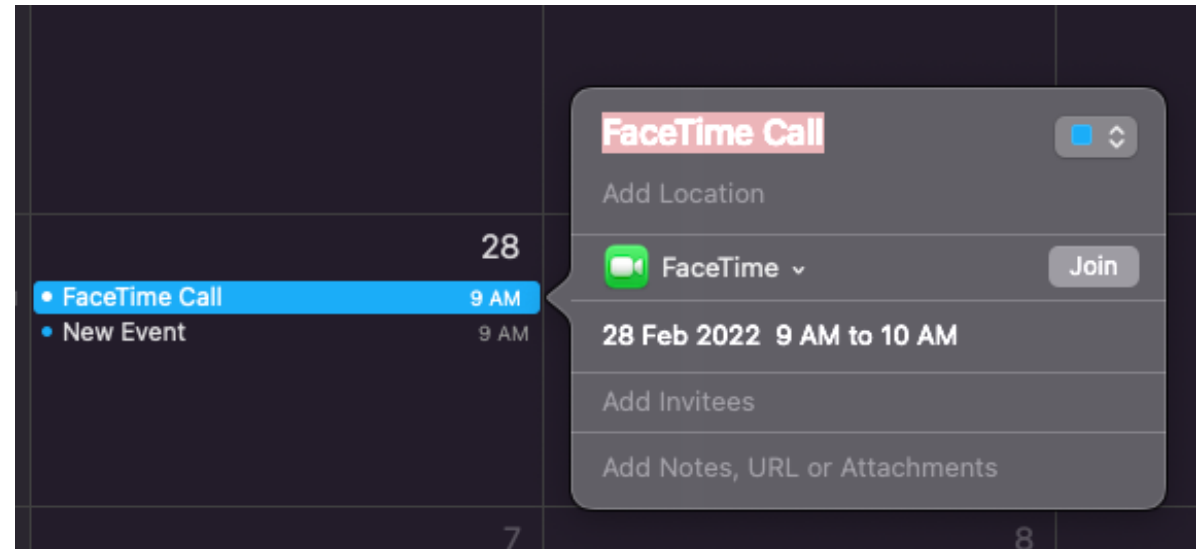
VMware Boxer iOS 

VMware Boxer Android 

Apple's weird parsing...

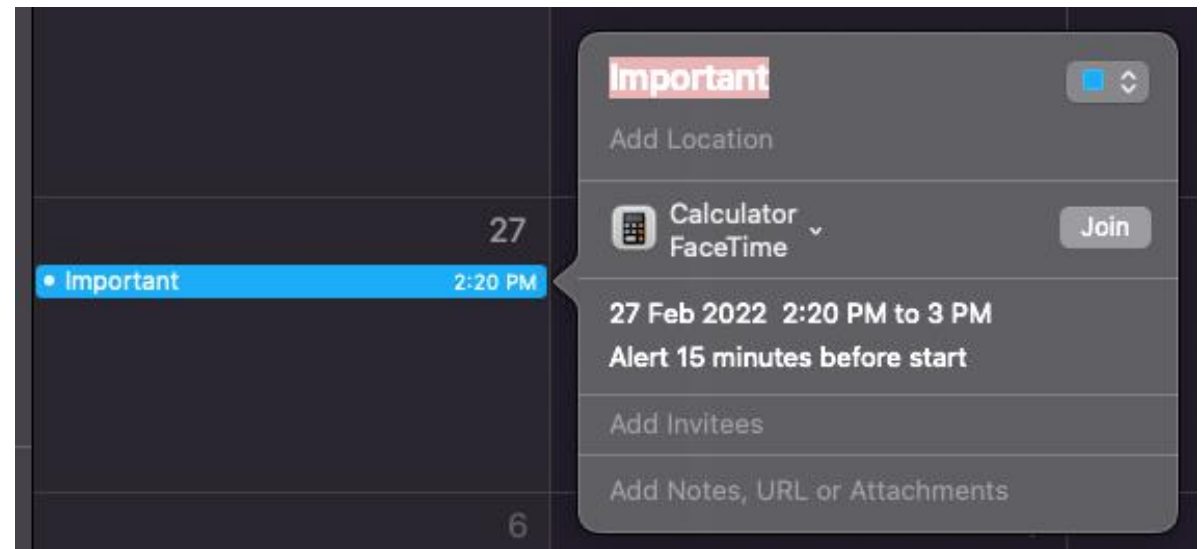
You Have One New Appwntment

```
DESCRIPTION:----( FaceTime )----  
\n[FaceTime]\nhttps://facetime.apple.com/join#v=1&p=...&k=...\n---  
===----
```



Please sir,
can I have
a custom
URI
exploit?

```
DESCRIPTION:----( FaceTime )----  
\n[FaceTime]\nFile:///System/Applications/Calculator.app\n-----
```



ATTENDEE / ORGANIZER properties

Property Name: ATTENDEE

Purpose: This property defines an "Attendee" within a calendar component.

Value Type: CAL-ADDRESS

Example:

ATTENDEE;MEMBER="mailto:DEV-
GROUP@example.com":mailto:joecool@example.com

The value is a URI... the value MUST be a mailto URI, as defined by RFC2368.

Don't assume anything!

```
"<script>alert()</script>"@evil.hax
```

 RFC approved!

Useful for red teams.

ATTACH URL



*.icloud.com?



Automatically
download

Vulnerable Proprietary Extensions to iCalendar



**A "standard
mechanism
for doing
non-
standard
things".**

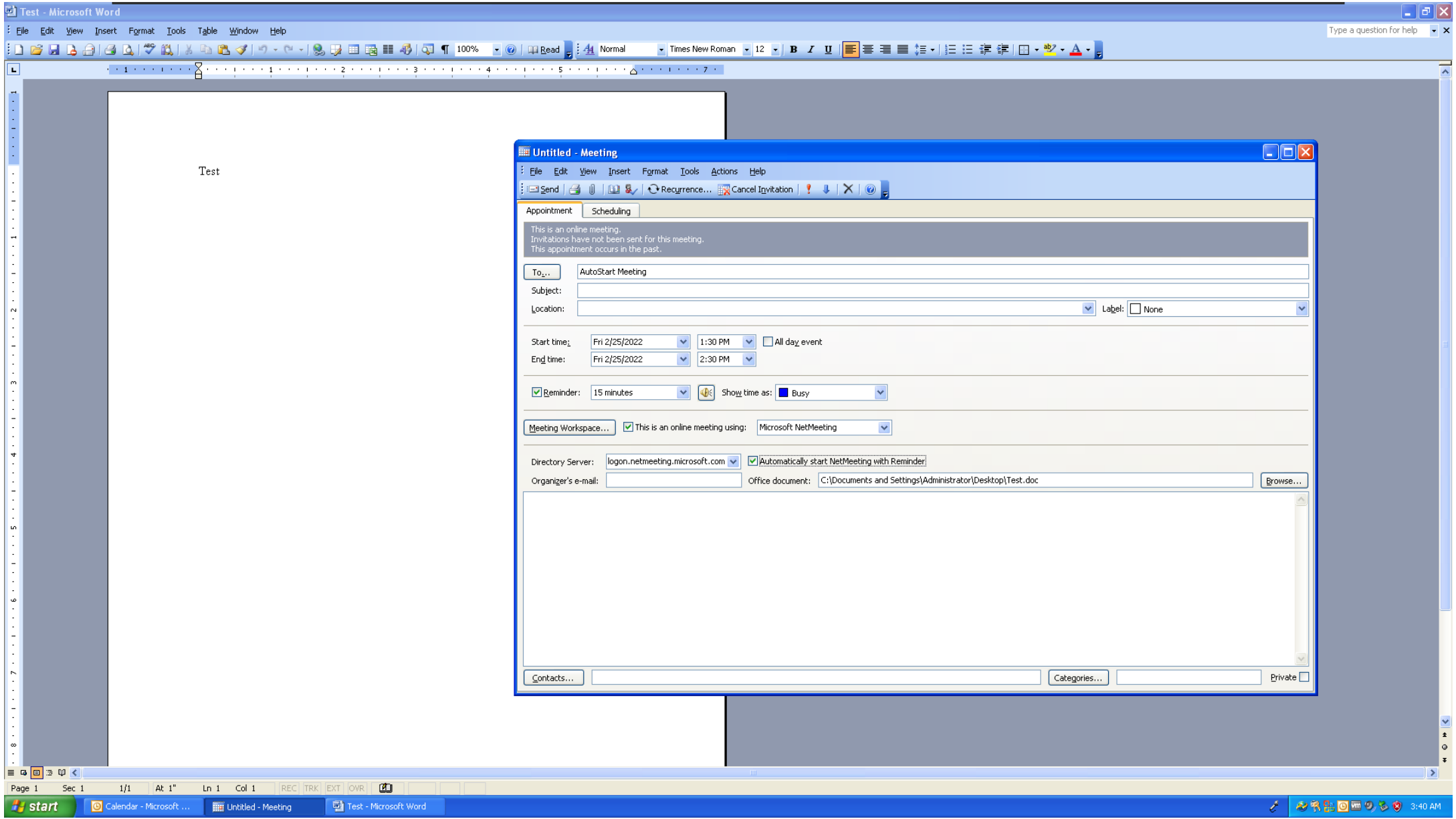
X-NON-STANDARD-PROPERTY

No registration authority =
wild wild west

The bad old days.

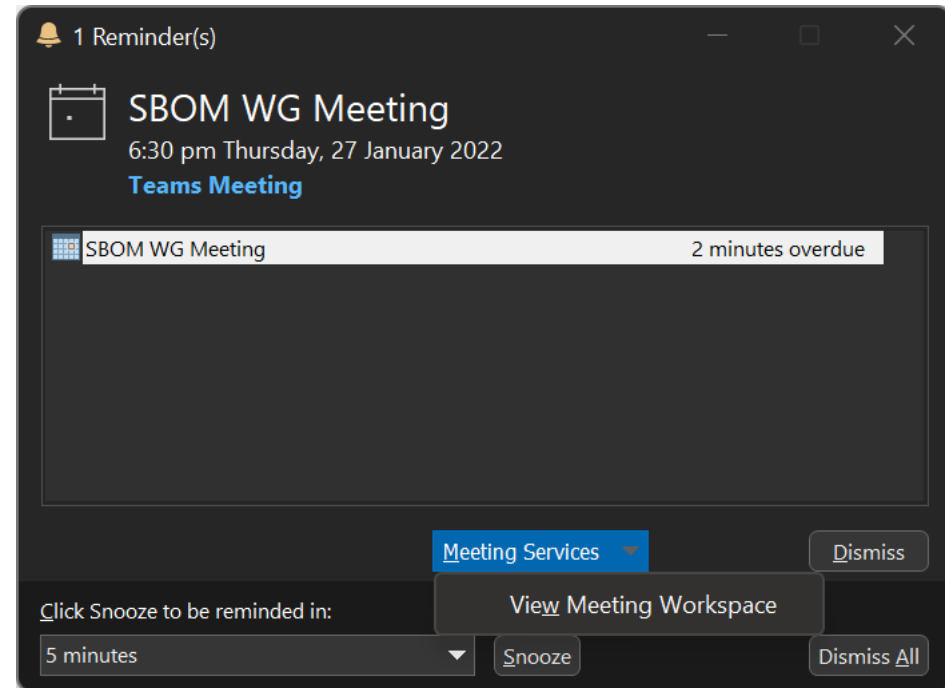
X-MS-OLK-AUTOSTARTCHECK: Specifies whether or not to **automatically start the conferencing application** when a reminder for the meeting fires.

X-MS-OLK-COLLABORATEDOC: Specifies the path to the conferencing collaboration document.



Zombie properties still exist.

X-MS-OLK-MWSURL: Specifies the URL of the Meeting Workspace.



Bypasses URI checks but too early for Follina 😞

Google patented a way to iframe widgets...

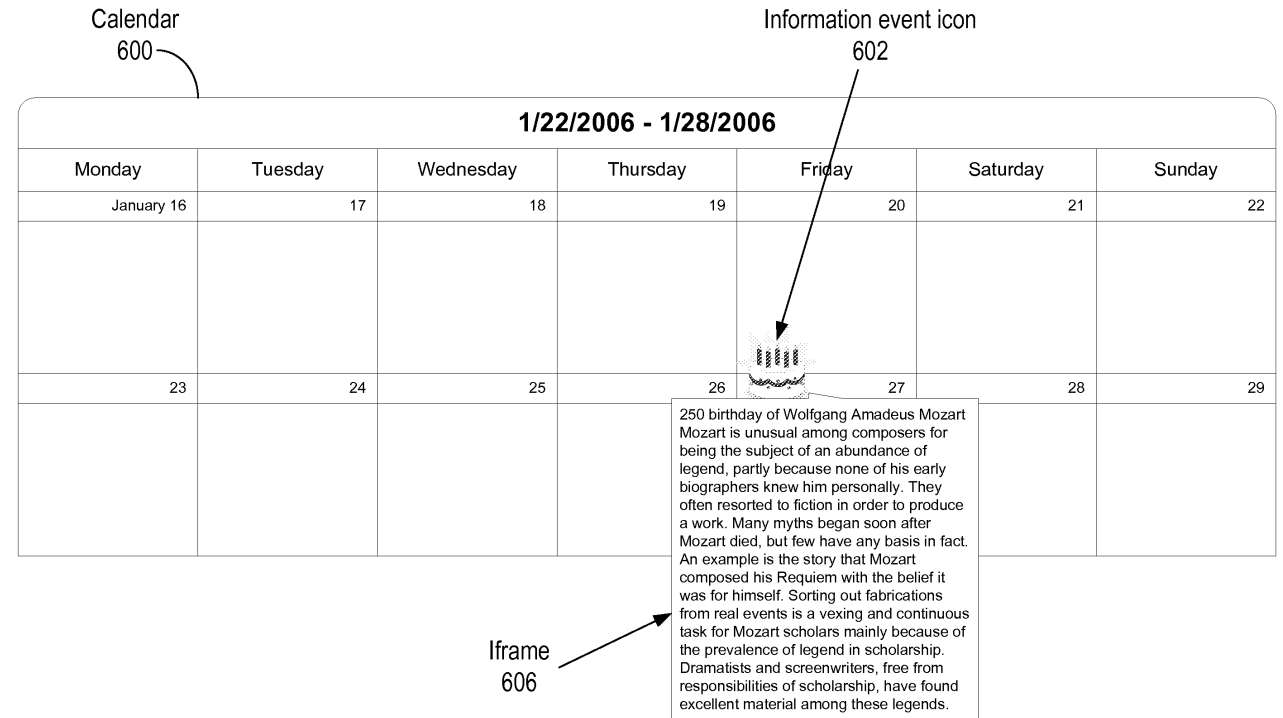


FIG. 6C

US20150169528A1 Calendar information events

We love loading remote content!

BEGIN:VCALENDAR

BEGIN:VEVENT

DTSTART:VALUE=DATE:20060704

DTEND:VALUE=DATE:20060705

SUMMARY:Independence Day

X-GOOGLE-CALENDAR-CONTENT-TITLE:Independence
Day

X-GOOGLE-CALENDAR-CONTENT-

ICON:<http://www.google.com/google-favicon.ico>

X-GOOGLE-CALENDAR-CONTENT-WIDTH:276

X-GOOGLE-CALENDAR-CONTENT-HEIGHT:120

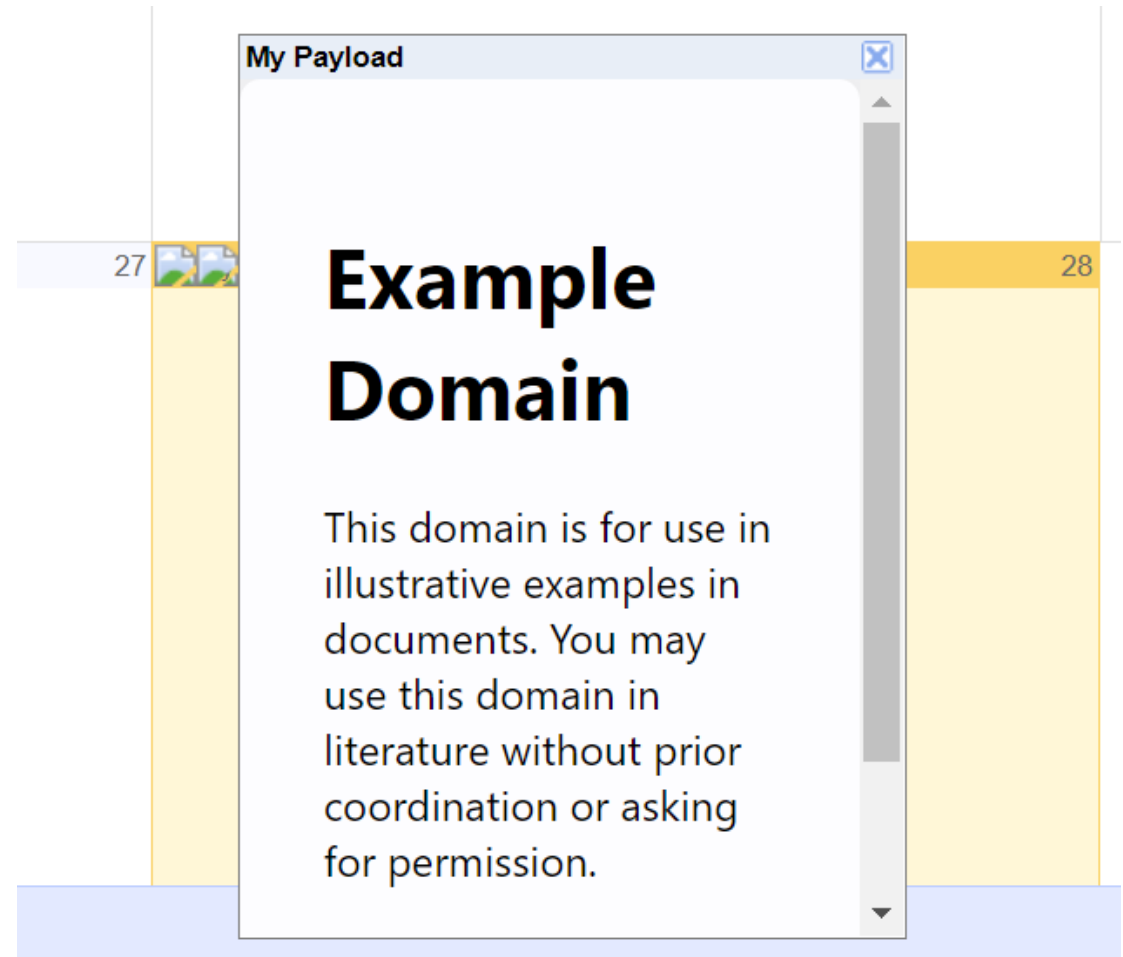
X-GOOGLE-CALENDAR-CONTENT-

URL:<http://www.google.com/logos/july4th06.html>

X-GOOGLE-CALENDAR-CONTENT-TYPE:text/html

END:VEVENT

Classics never die.



Eugene Lim

Today February 2022

Sun	Mon	Tue	Wed	Thu	Fri	Sat
30	31	Feb 1	2	3	4	5
6	7	8	9	10	11	12
13	14	15	16	17	18	19
20	21	22	23	24	25	26
27	28	Mar 1	2	3	4	5

9:30pm Research Collab Discussion

Windows Calendar Meeting

8am Meeting

12pm Test Skype Meeting

12:30pm Test Teams Meeting

11pm Eugene Lim's Zoom Meeting

12am Eugene Lim's Zoom Meeting

12am Test

11am Test

12pm Updated: SubjectT

1pm Test

1pm Test

My Payload

Events shown in time zone: Singapore Standard Time

Apple jerry-rigged its own data structures onto iCalendar.

```
X-APPLE-SUGGESTION-INFO-OPAQUE-  
KEY:|flightA2\\|SFO\\|JFK\\|A242\\|DUMMY  
X-APPLE-SUGGESTION-INFO-UNIQUE-  
KEY:|2|\\|flightA2\\\\\\\\\\|SFO\\\\\\\\\\|JFK\\\\\\\\\\|A242\\\\\\\\\\|DUMMY|\\|1  
8\\|\\\\\\\\\\|com.apple.Safari\\\\\\\\\\|AC4EB118-B1B3-4743-9B07-  
0B53C9FD5112  
X-APPLE-STRUCTURED-LOCATION;VALUE=URI;X-ADDRESS="San Francisco, CA  
94128, United States";X-APPLE-MAPKIT-  
HANDLE=CAES/gEIrk0QpMWb6...;X-APPLE-REFERENCEFRAME=0;X-TITLE=San  
Francisco International Airport:geo:37.616458,-122.385678  
X-APPLE-END-LOCATION;VALUE=URI;X-ADDRESS="John F. Kennedy  
International Airport, Jamaica, NY 11430, United States";X-APPLE-  
MAPKIT-HANDLE=CAES2AI...;X-TITLE=John F. Kennedy International  
Airport:geo:40.643575,-73.782034  
X-APPLE-STRUCTURED-  
DATA:YnBsaXN0MDDUAEEAAgADAAQABQAGAAcAClgkdmVyc2lublkkY...
```



Decodes to binary property list NSKeyedArchiver format!

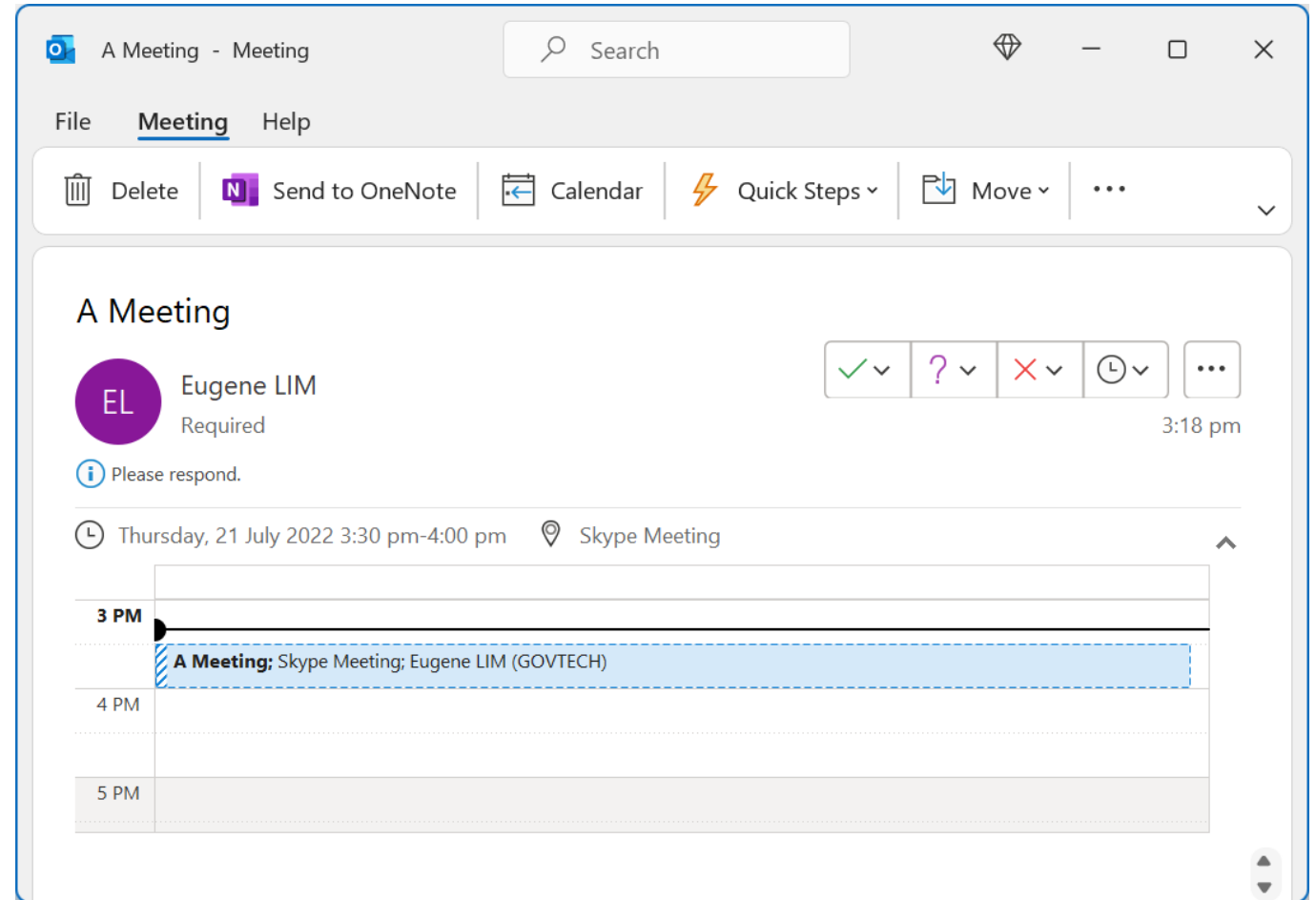
All this for a flight reservation.

```
<?xml version="1.0" encoding="UTF-8"?>
<!DOCTYPE plist PUBLIC "-//Apple//DTD PLIST 1.0//EN"
    "http://www.apple.com/DTDs/PropertyList-1.0.dtd">
<plist version="1.0">
<dict>
  <key>SGEventMetadataKey</key>
  <dict>
    <key>SGEventMetadataBundleIdKey</key>
    <string>com.apple.Safari</string>
    <key>SGEventMetadataCategoryDescriptionKey</key>
    <string>Flight</string>
    <dict>
      <key>@type</key>
      <string>http://schema.org/PostalAddress</string>
      <key>addressCountry</key>
      <string>United States</string>
      ...
    
```

Interactions with SMTP and CalDAV



What happens when you accept the invitation?



iCalendar interacts with SMTP.

You Have One New Appwntment

Accept invitation

Send email with ICS
attachment via SMTP

Calendar server
parses acceptance

ATTENDEE;PARTSTAT=ACCEPTED;CN=
Eugene Lim:mailto:<ATTENDEE EMAIL>

What could go wrong?

You Have One New Appwntment

ORGANIZER;CN=Attacker:mailto:**b@a.com**



User accepts invitation;
Calendar client sends email

EHLO mailserver.com
MAIL FROM "target@user.com"
RCPT TO "**b@a.com**"



@securinti

How about
newlines?

Still a valid email btw...

You Have One New Appwntment

ORGANIZER;CN=Attacker:mailto:b(\nEHLO a\n)@a.com



User accepts invitation;
Calendar client sends email

```
EHLO mailserver.com
MAIL FROM "target@user.com"
RCPT TO "b(
EHLO a
)@a.com"
```

SMTP command injection!



@securinti

Nice one!

Impact depends on SMTP server support.

You Have One New Appwntment

```
20 {
21 {
    "status": "error",
    "message":
    "Could not send mail: Expected response code 354 but got code \"250\", with message \"250-smtp.gmail.com at your service, [116.89.6.224]\r\n250-SIZE 35882577\r\n250-8BITIME\r\n250-AUTH LOGIN PLAIN XOAUTH2 PLAIN-CLIENTTOKEN OAUTHBEARER XOAUTH\r\n250-ENHANCEDSTATUSCODES\r\n250-PIPELINING\r\n250-CHUNKING\r\n250 SMTPUTF8\r\n\"",
    "data": {
        "type": "OCA\\Calendar\\Exception\\ServiceException",
        "message":
        "Could not send mail: Expected response code 354 but got code \"250\", with message \"250-smtp.gmail.com at your service, [116.89.6.224]\r\n250-SIZE 35882577\r\n250-8BITIME\r\n250-AUTH LOGIN PLAIN XOAUTH2 PLAIN-CLIENTTOKEN OAUTHBEARER XOAUTH\r\n250-ENHANCEDSTATUSCODES\r\n250-PIPELINING\r\n250-CHUNKING\r\n250 SMTPUTF8\r\n\"",
        "code": 250,
        "trace": [
            {
                "file": "\\var\\www\\nextcloud\\apps\\calendar\\lib\\Service\\Appointments\\BookingService.php",
                "line": 154,
                "function": "sendConfirmationEmail",
                "class": "OCA\\Calendar\\Service\\Appointments\\MailService"
            },
            {
                "file": "\\var\\www\\nextcloud\\apps\\calendar\\lib\\Controller\\BookingController.php",
                "line": 175,
                "function": "book",
                "class": "OCA\\Calendar\\Service\\Appointments\\BookingService"
            },
            {
                "file": "\\var\\www\\nextcloud\\lib\\private\\AppFramework\\Http\\Dispatcher.php",
                "line": 217,
                "function": "bookSlot",
                "class": "OCA\\Calendar\\Controller\\BookingController"
            },
            {
                "file": "\\var\\www\\nextcloud\\lib\\private\\AppFramework\\Http\\Dispatcher.php",
                "line": 126,
                "function": "executeController",
                "class": "OC\\AppFramework\\Http\\Dispatcher"
            },
            {
                "file": "\\var\\www\\nextcloud\\lib\\private\\AppFramework\\App.php",
                "line": 157,
                "function": "dispatch",
                "class": "OC\\AppFramework\\Http\\Dispatcher"
            },
            {
                "file": "\\var\\www\\nextcloud\\lib\\private\\Route\\Router.php",
                "line": 302,
                "function": "main",
                "class": "OC\\AppFramework\\App"
            },
            {
                "file": "\\var\\www\\nextcloud\\lib\\base.php",
                "line": 1006,
                "function": "main"
            }
        ]
    }
}
```

When API fails, try CALDAV?

Google

Deprecating

Microsoft

Transition to Graph

Lark Suite

Read-Only

Future Steps and Takeaways



The evolution of iCalendar is more jerry-rigging 😞

X-MICROSOFT-

```
SKYPETEAMSPROPERTIES:{"cid":"19:meeting_...@thread.v2","\,"private":true","\,"type":0","\,"mid":0","\,"rid":0","\,"uid":null}
```

X-MICROSOFT-

```
LOCATIONS:[{"DisplayName":"https://us04web.zoom.us/j/...","\,"LocationAnnotation":"","","\,"LocationUri":"","","\,"LocationStreet":"","","\,"LocationCity":"","","\,"LocationState":"","","\,"LocationCountry":"","","\,"LocationPostalCode":"","","\,"LocationFullAddress":"",""}]
```

Standardize
your own
parsing
internally?

[MS-OXCICAL]: iCalendar to Appointment Object Conversion Algorithm

Article • 08/18/2021 • 4 minutes to read



Specifies the iCalendar to Appointment Object Conversion Algorithm, which converts between IETF RFC 2445, RFC 2446, and RFC 2447, and appointment and meeting objects.

This page and associated content may be updated frequently. We recommend you subscribe to the [RSS feed](#) to receive update notifications.

Published Version

Date	Protocol Revision	Revision Class	Downloads
8/17/2021	13.0	Major	PDF DOCX

[Click here to download a zip file of all PDF files for Exchange Server Protocol Documents.](#)

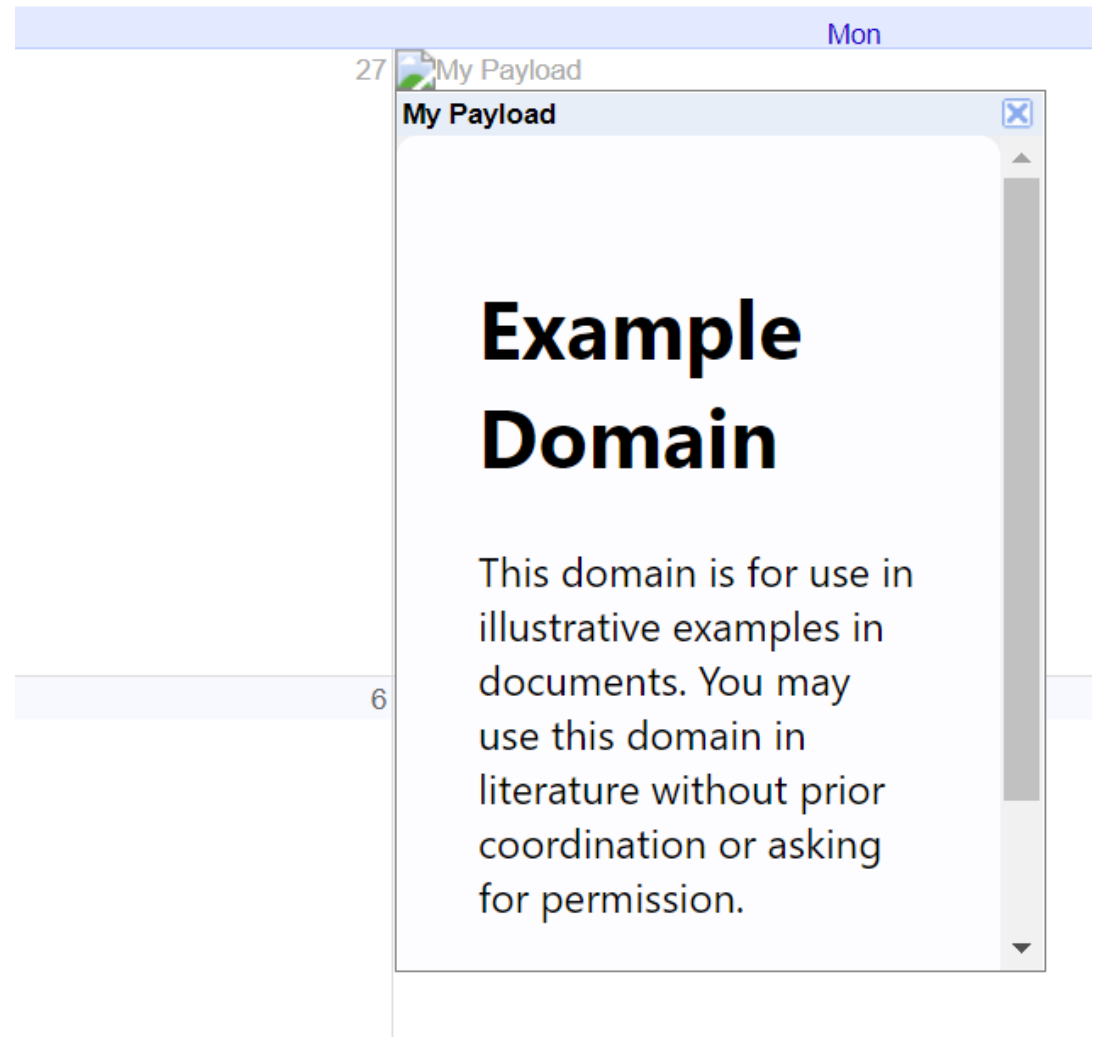
Contribute to open parsing standards.

9. Security Considerations

In addition to the security properties of iCalendar (see [Section 7 of \[RFC5545\]](#)), a "VALARM", if not monitored properly, can be used to disturb users and/or leak personal information. For instance, an undesirable audio alert could cause embarrassment; an unwanted display alert could be considered an annoyance; or an email alert could be used to leak a user's location to a third party or to send unsolicited email to multiple users. Therefore, CalDAV clients and servers that accept iCalendar data from a third party (e.g., via iCalendar Transport-Independent Interoperability Protocol (iTIP) [\[RFC5546\]](#), a subscription feed, or a shared calendar) SHOULD remove each "VALARM" from the data prior to storing in their calendar system.

Security considerations related to unique identifiers for "VALARM" are discussed in [Section 4](#).

**Stay frugal
with non-
standard
behavior.**



There's still lots more properties to research!

spaceraccoon.github.io/icalendardb



Thank you!



Eugene Lim

@spaceraccoonsec

spaceraccoon.dev